

Contents

Volume 03 — Metasploit, MITM & Crypto I (L21-L30)	2
L21: Metasploit — Exploiting System Software I	2
Learning objectives	2
What this lecture teaches	3
Tools mentioned	8
Commands / syntax from the lecture	8
Key terms	8
Exam-oriented recap	9
L22: Metasploit — Exploiting System Software II	9
Learning objectives	9
What this lecture teaches	9
Tools mentioned	12
Commands / syntax from the lecture	13
Exam-oriented recap	13
L23: Metasploit — Exploiting System Software and Privilege	13
Learning objectives	13
What this lecture teaches	14
Tools mentioned	17
Commands / syntax from the lecture	17
Key terms	17
Exam-oriented recap	18
L24: Metasploit — Social Engineering Attack	18
Learning objectives	18
What this lecture teaches	18
Tools mentioned	21
Commands / syntax from the lecture	23
Key terms	23
Exam-oriented recap	23
L25: MITM (Man-in-the-Middle) Attack	23
Learning objectives	23
What this lecture teaches	24
Tools mentioned	28
Commands / syntax from the lecture	29
Key terms	29
Exam-oriented recap	29
L26: Basic Concepts of Cryptography	29
Learning objectives	29
What this lecture teaches	30
Key terms	35
Exam-oriented recap	36

L27: Private-Key Cryptography — Part I	36
Learning objectives	36
What this lecture teaches	37
Key terms	42
Exam-oriented recap	43
L28: Private-Key Cryptography — Part II	43
Learning objectives	43
What this lecture teaches	43
Key terms	48
Exam-oriented recap	49
L29: Public-Key Cryptography — Part I	49
Learning objectives	49
What this lecture teaches	49
Key terms	54
Exam-oriented recap	55
L30: Public-Key Cryptography — Part II	55
Learning objectives	55
What this lecture teaches	56
Key terms	61
Exam-oriented recap	61

Volume 03 — Metasploit, MITM & Crypto I (L21-L30)

Course: NPTEL Ethical Hacking (106105217) · **Instructor:** Prof. Indranil Sengupta, IIT Kharagpur

Series: notes-2 (transcript-grounded) — Metasploit exploitation, social engineering, ARP/MITM, cryptography foundations.

Study notes derived from YouTube/Digimat lecture captions. For authorized lab use and exam preparation only.

L21: Metasploit — Exploiting System Software I

Transcript: [21-metasploit-exploiting-system-software-i.md](#)

Video: <https://www.youtube.com/watch?v=chU9BJSFjcg>

Week / theme: Week 5 — Nessus, system hacking, malware, ARP/MITM

Instructor: Prof. Indranil Sengupta, IIT Kharagpur

Learning objectives

- Alternatively, we can also use net discover command to find out all the live host in the network.

- So, before going to the Metasploit framework; we will now discuss about some basic terminology.
- First vulnerability; so we already discussed about vulnerability; again I will give a short description, short description of vulnerability.

What this lecture teaches

Core concepts from the lecture

In this session, we will discuss about the Metasploit framework and how to use Metasploit framework to penetrate inside the different operating system like windows XP, windows 7, may be higher version of windows or maybe other operating system like Linux and so on.

So, let us have example; suppose first I want to find out all the live host in the network.

So, you can use Nmap to find out all the live host in the network; Nmap dash T 4 dash sP; sP option is basically used to find out all the live host in the network 10 dot 35 dot 1 dot 0 slash 24; see we got all the live host in the network.

See it started from 10 dot 35 dot 1 dot 2; 1 dot 4 is also there; so, all the live host are listed here.

Alternatively, we can also use net discover command to find out all the live host in the network.

See you got 10 dot 35 dot 1 dot 2 and 10 dot 35 dot 1 dot 149, 10 dot 35 dot 1 dot 5; remaining system are also here listed 10 dot 35 dot 1 dot 144, 10 dot 35 dot 1 dot 139, 10 dot 35 dot 1 dot 239, 10 dot 35 dot 1 dot 169 and also 10 dot 35 dot 1 dot 90.

Ok, let us compare the result which we got using the Nmap; Nmap dash T 4 dash sP then 10 dot 35 dot 1 dot 0 slash 24; see so you got almost similar result.

So, now suppose we consider this machine is our target machine with the IP 10 dot 35 dot 1 dot 150.

Continued

So, let us start with some other type of scan likewise scan, service scan and port scan also.

So, using Nmap; we can perform port scan; for port scanning we used as small p option; we already know that and followed by the port number.

So, suppose I want to scan first 1000 port; so Nmap dash T 4 dash p 0 or to 1000 port and then the IP address.

So, what target IP address is 10 dot 35 dot 1 dot 150.

So, here we only scan first 1000 port, but in real life scenario; we need to scan all the port starting from 0 to 65535.

And see port 135 is open, 139 is also open, 445 is also open.

So, now let us perform a service scan using Nmap; Nmap then timing option maybe T 4, then for service scan we use the option dash small s capital V, then the IP address; 10 dot 35 dot 1 dot 150.

It basically list all the services which is running in the target machine.

Continued

See corresponding version is also there in port 135, service msrpc is running and corresponding version is also there.

Port 139; that is also open, 445 that is also open and corresponding service and their version is also detected here right.

So, next try to find out the operating system of the target machine.

So, for operating system scanning we use the option dash capital O, ok.

We also got the operating system; it showing Microsoft window XP service pack 2 professional, ok.

So, now we also perform the vulnerability scan.

So, for vulnerability scanning; we use the tool Nessus, but currently we are using Nmap script to find out the vulnerability.

Nmap then I use the timing option T 4, then to run script, to use dash script option; then we use the script with the name vuln and then the IP address.

Continued

It will take some time to find out the vulnerabilities; we got the result.

Now, check the result for vulnerabilities in the target machine.

It is showing all the port which is open and the corresponding services; smb vuln ms 0 8 dash 067 that is vulnerable and it basically Microsoft window system vulnerability to remote code execution ok.

So, let us start exploit the target machine using this vulnerability.

So, to exploit this machine we use the tool or framework Metasploit.

So, before going to the Metasploit framework; we will now discuss about some basic terminology.

First vulnerability; so we already discussed about vulnerability; again I will give a short description, short description of vulnerability.

A vulnerability is weakness which can be exploited by an attacker to perform unauthorized action with the computer system.

Continued

A vulnerability can be as simple as weak password or as complex as buffer overflow or may be SQL injection vulnerabilities and so on.

Next exploit; exploit is a piece of code or a chunk of data or a sequence of commands that take the advantage of a vulnerability present in a computer system; to cause unintended behaviour to occur on a computer system such as giving unauthorized access to a system or allowing privilege escalation etc.

Payload, the payload is the part of the private user text which could also contain malware such as worm or viruses, which perform the milieus action deleting data, sending spam or encrypting data.

Auxiliary; auxiliary are module present in Metasploit that are used to perform scanning, sniffing and fussing.

Auxiliary module are not useful to give you a cell; that means, the access of the victim machine, but they are extremely useful to brute force, attack or for scanning vulnerabilities.

Post; post module are used for post exploitation that is used on a compromise target machine to gather evidence or deep within the network.

Now, let us start Metasploit framework.

So, to start Metasploit framework, we use the command msfconsole.

Continued

Metasploit project is an open source penetration testing platform that enable you to find and exploit vulnerabilities.

In 2003, HD Moore created Metasploit as a portable network tool.

On October 21st, 2009; the Metasploit project was acquired by Rapid 7.

The Metasploit project help security and it professional to identify security issues, verify vulnerability, mitigations and manage exploit tribunes security assessment.

The Metasploit project include subproject like Metasploit framework and its commercial counterpart Metasploit pro express, community and nexpose ultimate.

Now, I am discussing about some basic command of Metasploit after starting the Metasploit framework; we can check for the basic command by using help command in Metasploit.

So, by using the command help; we can get all the available command in Metasploit. See that is all the available command are showing in Metasploit.

Continued

To see all the payload that are available on the Metasploit framework we use the command show payloads.

At least all the available payloads in alphabetic order; see all the payload are listed here.

To see all the exploits that are available on the Metasploit framework; we use the command show exploits.

So, exploits here is the list of all the available exploit and Metasploit; similarly we can use; so auxiliary command to see all the list of auxiliary available in the Metasploit framework.

And also we can use show encoders command; to see the list of all the encoder available in Metasploit.

Now, let us start with the vulnerability which we got from the scanning.

So, we got the vulnerability ms 08 dash 067; so now, to scan is there any exploit available with regarding to the term ms 08 dash 067; we can use the command search; followed by the term ms 08 dash 067.

This is our scan result for the target machine; it is showing smb vuln ms 08 dash 067; this is the vulnerability and this is Microsoft window system vulnerability to remote code execution.

Continued

So, now using this vulnerability we will try to penetrate inside the target machine.

Now here is my Metasploit.

Now, we will search is there any exploit is present in the Metasploit framework with this particular vulnerability ms 08 dash 067.

So, to find out this we need to use the command search followed by the vulnerability name ms 08 dash 067.

It will basically show all the available exploit with exploit not only exploit it showing all the related exploit, auxialary payload related to the vulnerability ms 08 dash 067.

Ok, we got the exploit slash windows slash smb slash ms 08 underscore 067 underscore net api.

And it disclosure date is 2008 and 28th of October and rank is great.

Now, we will try to exploit the target system using this exploit which is available in Metasploit framework.

Continued

So, how to use this exploit?

To use any exploit we need to use the command use and then exploit.

Now, we need to set some parameter within this exploit; so how to check which parameter we need to set?

By using the so option command; we can check this ok.

We need to set RHOST; RHOST means remote host means target machine IP address. So, to set RHOST we need to use the command; set then RHOST, then IP address 10 dot 35 dot 1 dot 150.

Now, we also need to set RPORT; to set RPORT we need to use open port from the scanning face; we already find out the port 445 is open in the target machine.

So, it is already 445 port is selected; so no need to change this.

Continued

So, otherwise if you want to change this port we need to use the command set RPORT, then the port number 445.

Now by using the show options command; we can see that all the options are set and this time it did not do anything using the SMBPIPE.

Now to exploit the system, we use the command exploit or run.

So, this time we use the command exploit; started reverse TCP handler on the attacker machine.

So, this IP address 10 dot 35 dot 1 dot 153 is basically the attacker machine IP address and using the port 4444; this is also the port which is used by the attacker machine.

And see we got the meterpreter session; that means, we already enter inside the target system.

By using the command sysinfo, we can check the information about the target machine and see it showing windows XP and all the details of the target machine; so; that means, we are already now inside the target machine.

Now, we can perform some task from meterpreter session.

Continued

By using the command help we can check all the available command in meterpreter session.

Now see, lots of interesting commander here in meterpreter session; bg kill, kill a background meterpreter script.

Similarly, there is also some other command like download; download a file or directory from the victim machine.

Then we can also use mkdir to make a directory in the victim machine, we can also delete the directory from the victim machine.

We can also capture the screen, we can also able to on the web cam in the victim machine and microphone also.

We can also record remotely whatever the conversation is going on in front of the victim machine.

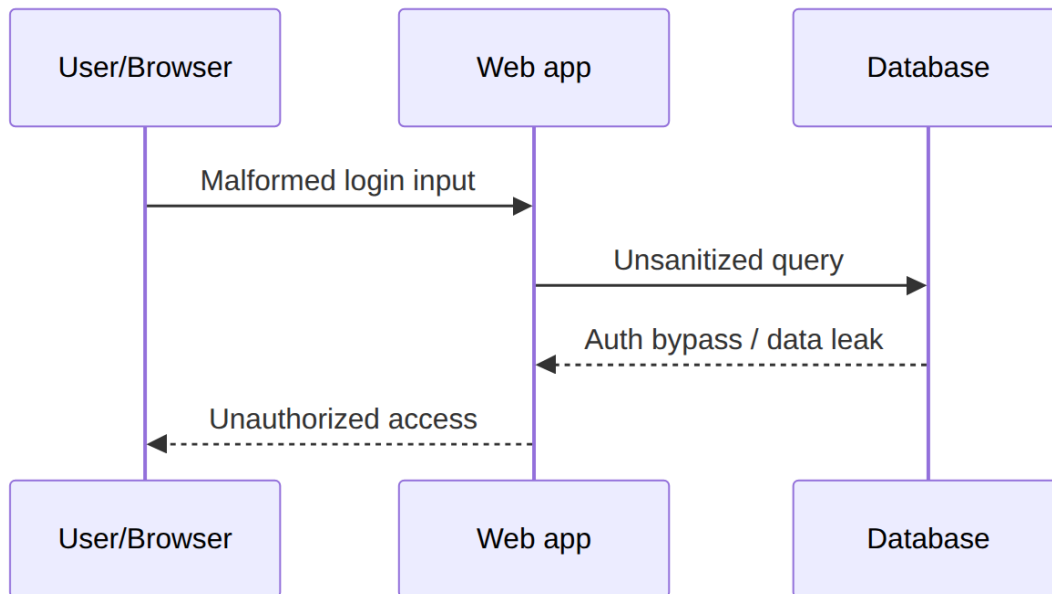


Figure 1: Architecture diagram

Tools mentioned

- Metasploit
- msfconsole
- Nessus
- Nmap

Commands / syntax from the lecture

- Nmap to find out all the live host in the network; Nmap dash T 4 dash sP; sP option i
- Nmap dash T 4 dash sP then 10 dot 35 dot 1 dot 0 slash 24; see so you got almost simi
- Nmap dash T 4 dash p 0 or to 1000 port and then the IP address
- Nmap then timing option maybe T 4, then for service scan we use the option dash small
- Nmap script to find out the vulnerability
- Nmap then I use the timing option T 4, then to run script, to use dash script option;

Key terms

Term	Meaning in this lecture
We need to set RHOST; RHOST	remote host means target machine IP address.

Exam-oriented recap

- So, now we also perform the vulnerability scan.
 - So, for vulnerability scanning; we use the tool Nessus, but currently we are using Nmap script to find out the vulnerability.
 - It is showing all the port which is open and the corresponding services; smb vuln ms 0 8 dash 067 that is vulnerable and it basically Microsoft window system vulnerability to remote code execution ok.
 - So, let us start exploit the target machine using this vulnerability.
 - First vulnerability; so we already discussed about vulnerability; again I will give a short description, short description of vulnerability.
 - A vulnerability is weakness which can be exploited by an attacker to perform unauthorized action with the computer system.
 - A vulnerability can be as simple as weak password or as complex as buffer overflow or may be SQL injection vulnerabilities and so on.
 - Auxiliary module are not useful to give you a cell; that means, the access of the victim machine, but they are extremely useful to brute force, attack or for scanning vulnerabilities.
-

L22: Metasploit — Exploiting System Software II

Transcript: [22-metasploit-exploiting-system-software-ii.md](#)

Video: <https://www.youtube.com/watch?v=qZ-F1YSvGI0>

Week / theme: Week 5 — Nessus, system hacking, malware, ARP/MITM

Instructor: Prof. Indranil Sengupta, IIT Kharagpur

Learning objectives

- Now, today our target IP address is 10 dot 35 dot 1 dot 155.
- So, in first phase we need to find out all the vulnerabilities of the target machine.
- So, in previous lesson, we already check how to find out the vulnerability using Nessus, alternatively we can also find all the vulnerability using the Nmap script vuln.
- Starting Nmap and it will take some time to give result, ok.
- It showing the port 135 TCP port is open, 139 TCP port open, port 445, 5357, 49152, 49153, 49154, 49155 and 49156 and 49157 TCP port is open.

What this lecture teaches

Core concepts from the lecture

Let us start with another example.

Now, today our target IP address is 10 dot 35 dot 1 dot 155.

So, in first phase we need to find out all the vulnerabilities of the target machine.

So, in previous lesson, we already check how to find out the vulnerability using Nessus, alternatively we can also find all the vulnerability using the Nmap script vuln.

So, directly go to the terminal Kali Linux and start to find the vulnerabilities using Nmap script vuln, Nmap, then timing option T4, then script name is vuln, and the IP address is 10 dot 35 dot 1 dot 155.

Starting Nmap and it will take some time to give result, ok.

It showing the port 135 TCP port is open, 139 TCP port open, port 445, 5357, 49152, 49153, 49154, 49155 and 49156 and 49157 TCP port is open.

And it showing samba vuln cve 2012 dash 1182 STATUS ACCESS DENIED.

Continued

Smb vuln MS 01 dash 054, it also showing false, smb vuln MS 10 dash 061 STATUS ACCESS DENIED, smb vuln MS 17 dash 010, it showing VULNERABLE.

And REMOTE CODE EXECUTION VULNERABILITY IN MICROSOFT SMB version 1 server, so it showing in the target machine ms 17 dash 010 vulnerability is present.

Now, we use Metasploit framework to exploit the target machine using the vulnerability name ms 17 dash 010.

Let us start Metasploit.

So, by using the command msfconsole we can open Metasploit.

Now, search for the exploit in Metasploit framework related to the vulnerability name ms 17 dash 010.

We got two auxiliary and two exploit.

So, here we all only concern about the exploit.

Continued

Exploit windows smb MS 17 underscore 010 underscore eternal blue.

Disclosure date is 2017.

And next one is exploit windows smb MS 17 underscore 010 underscore psexec.

Disclosure date is also in 2017.

So, let us start with the exploit windows smb MS 17 underscore 010 underscore eternal blue.

To use this exploit we use the command use followed by the exploit name.

Now, to check the available option we need to use the command, show options.

Now, among from this all these option now we only concern about the RHOTS that is remote host means the IP address of the victim machine and RPORT; that means, a open port of the victim machine.

Continued

So, now, set RHOST 10 dot 35 dot 1 dot 155 which is the IP address of the target machine.

And by default port 445 is selected.

And from the previous result a vulnerability scanning we see port 445 is open in the target machine.

So, no need to change the RPORT 445.

Now, use the command exploit or run.

Started reverse TCP handler on the attacker machine with IP address 10 dot 35 dot 1 dot 153 and port 4444.

Wow, we get the shell of the victim machine.

Now, this is the command prompt of the victim machine.

Continued

We can do anything from my attacker machine; that means, from my kali machine to the victim machine using this shell.

So, this shell is basically the cmd of the victim machine.

So, by using the command dir we can check all the directory of the directory and file in system 32.

Alternatively, we can also check any other list of directory in the victim machine.

Suppose, you want to check all the list of the file and directory in C drive, then go to the file system C and then use the command dir, ok.

We got all the list of file and directories in C drive.

So, this is all the list of the directories.

Now, we can also delete a directory or file we can also create a file or directory in the specified location.

Continued

By using the command mkdir we can create a directory in the specified location.

Now, see I am creating a directory with the name hack.

Now, check by the command dir and see a directory hack is created in C drive.

Similarly, we can also delete any directory from any specified location.

By using the command rmdir we can remove any directory.

Suppose, now I want to remove the previously created directory hack, so rmdir then the directory name hack, directory deleted.

Now, to check use dir command.

Now, see there is no directory with the name hack.

Continued

So, this is basically the command prompt of the victim machine.

So, by using the command prompt of the victim machine from my Kali Machine, I can handle the attacker, I can handle the Victim Machine.

So, I am closing the session here now and I will discuss further in the next session about the Metasploit framework.

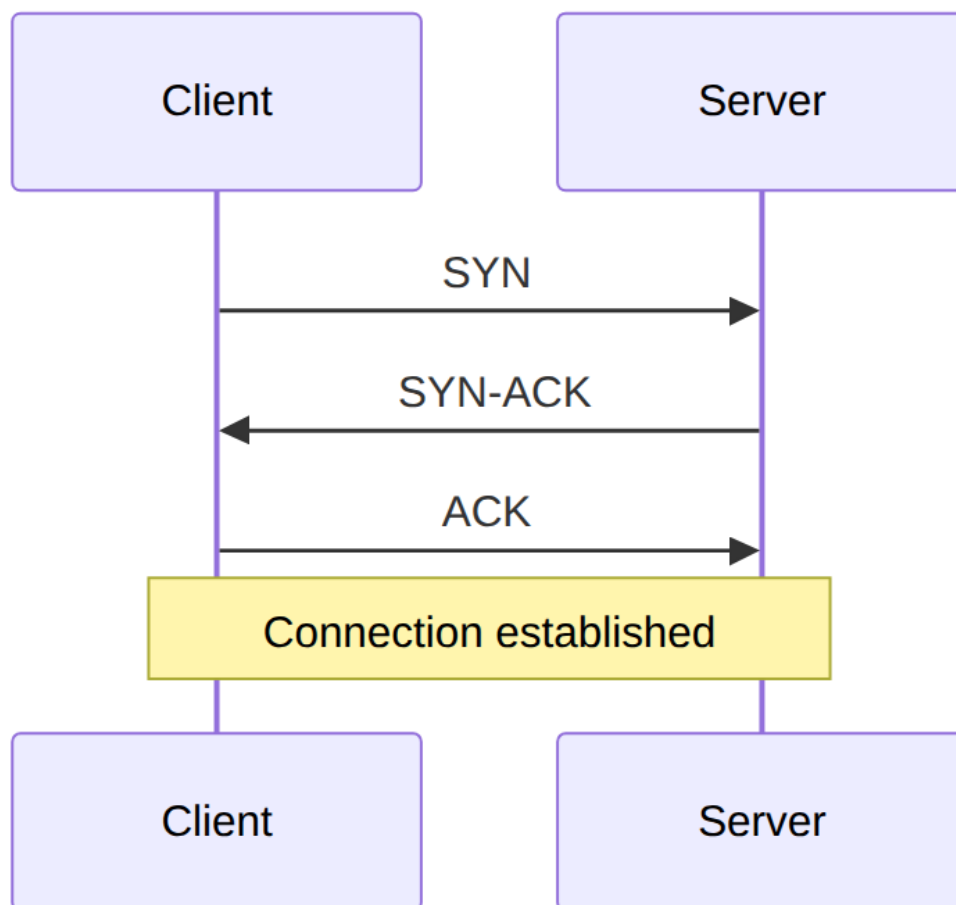


Figure 2: Architecture diagram

Tools mentioned

- Kali Linux
- Metasploit
- msfconsole

- **Nessus**
- **Nmap**

Commands / syntax from the lecture

- Nmap script vuln
- Nmap script vuln, Nmap, then timing option T4, then script name is vuln, and the IP a
- Nmap and it will take some time to give result, ok
- msfconsole we can open Metasploit

Exam-oriented recap

- So, in previous lesson, we already check how to find out the vulnerability using Nessus, alternatively we can also find all the vulnerability using the Nmap script vuln.
- And REMOTE CODE EXECUTION VULNERABILITY IN MICROSOFT SMB version 1 server, so it showing in the target machine ms 17 dash 010 vulnerability is present.
- Now, we use Metasploit framework to exploit the target machine using the vulnerability name ms 17 dash 010.
- Now, search for the exploit in Metasploit framework related to the vulnerability name ms 17 dash 010.
- And from the previous result a vulnerability scanning we see port 445 is open in the target machine.
- Started reverse TCP handler on the attacker machine with IP address 10 dot 35 dot 1 dot 153 and port 4444.
- We can do anything from my attacker machine; that means, from my kali machine to the victim machine using this shell.
- So, by using the command prompt of the victim machine from my Kali Machine, I can handle the attacker, I can handle the Victim Machine.

L23: Metasploit — Exploiting System Software and Privilege

Transcript: [23-metasploit-exploiting-system-software-and-privilege.md](https://www.youtube.com/watch?v=dk1qBNgRH9k)

Video: <https://www.youtube.com/watch?v=dk1qBNgRH9k>

Week / theme: Week 5 — Nessus, system hacking, malware, ARP/MITM

Instructor: Prof. Indranil Sengupta, IIT Kharagpur

Learning objectives

- In previous session, we had discussed about system software vulnerability.

- Now in the session we will discuss about the Application Software Vulnerability and using that particular vulnerability, how to penetrate inside windows machine.
- So, first we will perform a port scan Nmap dash T4, then dash P.
- Now we will exploit the vulnerability of the http service of the particular version BadBlue httpd 2.7.
- So, we will use this particular exploit.

What this lecture teaches

Core concepts from the lecture

In previous session, we had discussed about system software vulnerability.

Now in the session we will discuss about the Application Software Vulnerability and using that particular vulnerability, how to penetrate inside windows machine.

Now consider that our target IP address is 10.35.1.199, ok.

So, let us start from the scanning part.

So, first we will perform a port scan Nmap dash T4, then dash P.

For the time being I am performing the port scan for port 1 to 1000, then the IP address 10.35.1.199 ok.

Port 80 is open http service is running.

Port 135 is also open, 139, 445 all TCP ports are open.

Continued

Now, perform a service scan Nmap timing option dash T4, then dash sV for service scan, then the IP address 10.35.1.199.

So far better visualisation we are performing service scan and also to know the details of the service means what particular version of the service is running in the target machine, ok.

In port 80, http service is running and the version of the http services is BadBlue httpd 2.7.

From the experience we know that this service BadBlue httpd 2.7 is a vulnerable service and this service is basically used to transfer file.

Now we will exploit the vulnerability of the http service of the particular version BadBlue httpd 2.7.

Let us start Metasploit framework.

Now, in Metasploit framework search for the exploit related to the badblue service.

So, we got two exploit; one is exploit slash windows slash http slash underscore ext underscore overflow and the disclosure date is in 2003 and rank is great and second one is exploit slash windows slash http slash badblue underscore pass thru.

Continued

Disclosure date is 2007 and rank is great and in description we clearly see that this is for the BadBlue version 2.7.

So, we will use this particular exploit.

Now, using show options command we can see all the options which we need to set.

So, we need to set RHOST.

So, use the command set, then RHOST, then the machine IP address is 10.35.1.199 and RPORT is already set as 80 and http dbadblue service is also running in port rightly.

So, no need to change RPORT.

Now use the command exploit, meterpreter session one is open with the host machine 10.35.1.1980 using the port 4444 and we got the meterpreter session.

Now, by using the command sysinfo we can check the information of the target machine.

Continued

It is Windows 7, great.

So, by using the vulnerability of the application software BadBlue 2.7 we successfully exploit the target system.

Now, from the meterpreter section we can execute lots of command which is available in meterpreter.

By typing help we can check all the available command.

One of the important command is hashdump.

By using the command hashdump, we can dump the content of the same database that means the password of the target machine, but in this scenario hashdump is not working.

Now check the privilege of this user.

So, the server username is WIN then U07C2K something, then slash exploiter.

Continued

So, this session do not have the administrative privilege.

So, to get the hash, to execute the hashdump command we need to escalate the administrative privilege first.

So, now before getting the administrator privilege I do one thing.

I simply migrate the process into any other legitimate and stable process.

So, by typing the command ps we can get all the process list.

See here is all the process list with their process Id and parent process id.
So, now I am going to migrate the process into iexplore.exe with the process Id 2176.
So, the command is migrate, then process Id 2176.

Continued

See migration completed successfully.
Now send this meterpreter session in background by using the command background.
Now check all the meterpreter session.
So, there is only one meterpreter session with the session Id 2 and it do not have the administrative privileges.
Now for further to get the administrator privileges, we use some post exploit related to the term bypassuac.
So, search for all the available exploit with the term bypassuac.
Now, suppose I want to use the first one.
Now by using the command show options we can check all the options we need to set within this particular exploit.

Continued

So, now see we need to set the session.
Now we want to send the session Id 2 with the administrative privilege.
So, set SESSION as 2.
Now see all the options are set.
Now use the command exploit.
Started the reverse TCP handler with the IP 10.351.198 using the port 4444 and meterpreter session 3 is open now.
Now, check the privilege of this particular session by using the command getuid.
Now still it do not have the administrative privilege.

Continued

Now use the command, getsystem, got system via technique 1 in memory admin.
Now, check the privilege of this particular session.
Now see we got the system privilege, that means the administrative privilege.
Now, use the command hashdump and see we got the hash value of the password of the target machine.
So, this way we can also escalate the privilege of the target machine.

Now in the next session, we will discuss about the Social Engineering Attack by using the exploit or payload available in the Metasploit framework.

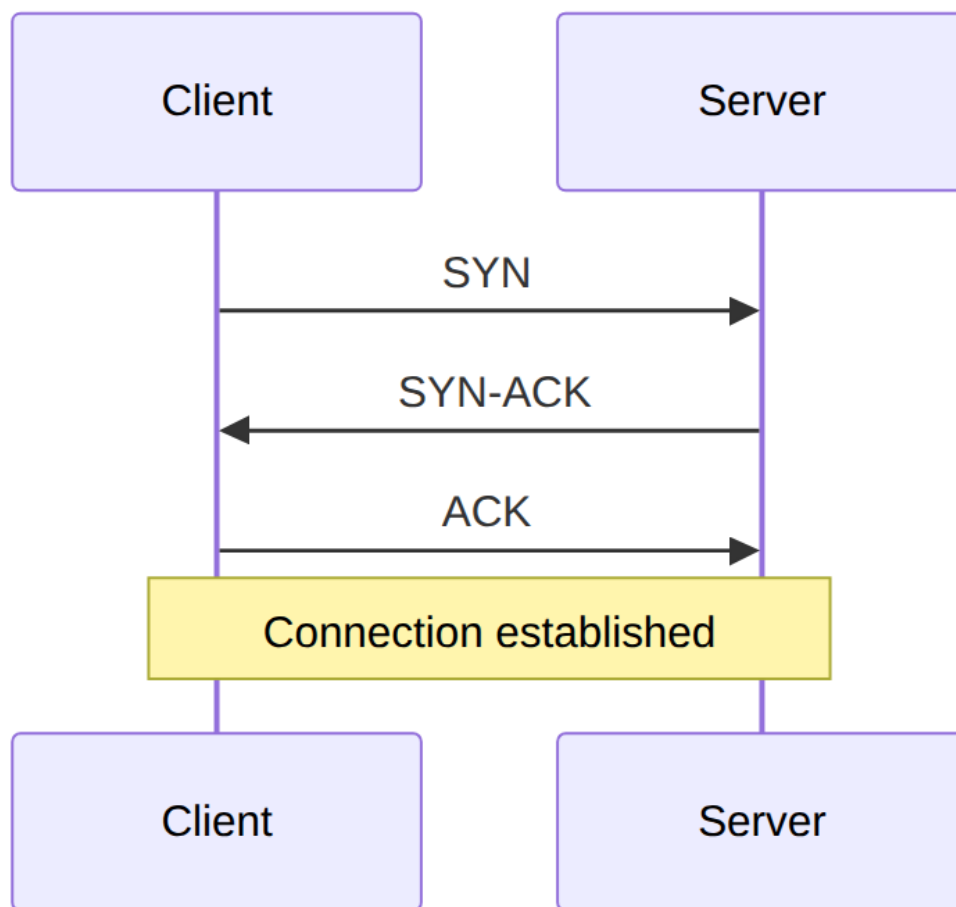


Figure 3: Architecture diagram

Tools mentioned

- Metasploit
- Nmap

Commands / syntax from the lecture

- Nmap dash T4, then dash P
- Nmap timing option dash T4, then dash sV for service scan, then the IP address 10

Key terms

Term	Meaning in this lecture
Now see we got the system privilege, that	the administrative privilege.

Exam-oriented recap

- In previous session, we had discussed about system software vulnerability.
- Now in the session we will discuss about the Application Software Vulnerability and using that particular vulnerability, how to penetrate inside windows machine.
- Now we will exploit the vulnerability of the http service of the particular version BadBlue httpd 2.7.
- So, by using the vulnerability of the application software BadBlue 2.7 we successfully exploit the target system.
- One of the important command is hashdump.
- Now in the next session, we will discuss about the Social Engineering Attack by using the exploit or payload available in the Metasploit framework.

L24: Metasploit — Social Engineering Attack

Transcript: [24-metasploit-social-engineering-attack.md](#)

Video: <https://www.youtube.com/watch?v=tWDZjzoupY8>

Week / theme: Week 5 — Nessus, system hacking, malware, ARP/MITM

Instructor: Prof. Indranil Sengupta, IIT Kharagpur

Learning objectives

- Now, in this session we will discuss about Social Engineering Attack.
- In this session we will use social engineering as an attack vector to compromise target system.
- We will cover SE toolkit in next session.
- We will use the tool MSF Venom which is a companion script with Metasploit.

What this lecture teaches

Core concepts from the lecture

Now, in this session we will discuss about Social Engineering Attack.

In this session we will use social engineering as an attack vector to compromise target system.

Social engineering is the term used for a broad range of malicious activities accomplished through human interactions.

It uses psychological manipulation to trick user into making security mistakes or giving away sensitive information.

The term can also include activities such as exploiting human kindness, greed and curiosity to gain access to restricted access building or getting the users to installing backdoor software.

Social engineering technique involves email, website, Java, Applet, HIT device.

Sometimes malware are bind with other legitimate file like image, PDF etc of the victim interest.

So, there are variety of techniques used for Social Engineering Attack.

Continued

Best tool for Social Engineering Attack is SE toolkit.

We will cover SE toolkit in next session.

In this session I will show something I built from scratch.

Now I am going to convert the payload into an executable and then using social engineering, execute into the target system and compromise it.

We will use the tool MSF Venom which is a companion script with Metasploit.

So, run msfvenom, without any argument you will get a list how to use it.

So, let us check msfvenom.

So, see the help is here and you can check how to use msfvenom.

Continued

To check the list of all payload, we can use the command msfvenom dash l.

So, all the list of payload.

Now, see here is the list of all the payloads available in msfvenom.

Now, see there is a payload with the name windows slash meterpreter slash reverse underscore tcp.

Now we are going to use this particular payload and create the executable and by using this payload, we try to establish a reverse connection from target machine to attacker machine.

So, first see how to create the binaries or executable using this particular payload.

So, now I am using msfvenom, then dash p specify the payload name.

So, now the payload name is windows slash meterpreter slash reverse underscore tcp.

Continued

Now we need to set the LHOST.

LHOST means basically the IP address of the attacker machine.

That means, IP address of the kali machine that is 10.35.1.198 because, we are basically going to establish the reverse connection.

That means whenever we execute these executable in the target machine, it establish the connection with the host IP address 10.35.1.198 and we can also set the LPORT.

So, LPORT I am using here 443.

Now, dash f specify the file format I am going to create the exe file.

Now put the location where you want to store this executable file.

I am going to store this executable file in root under my file directory and the file name is maybe flash8.exe.

Continued

Now check the folder.

Now see it is already created.

Now our main aim is execute this exe file into the target machine using any kind of social engineering attack like maybe through email, maybe by website or any other social engineering attack vector.

Now, in attacker machine we also need to open the handler which can able to listen the connection which is coming from the target machine, that means where we execute this file.

So, to open the handler we need to open Metasploit framework.

So, by typing msfconsole I am opening the Metasploit framework.

Now, we need to open the handler.

So, the command is use exploits slash multi slash handler.

Continued

Now we need to set the payload.

So, we use the payload windows slash meterpreter slash reverse underscore tcp.

Now by using the show option command we can check all the options we need to set under this particular payload.

So, we need to set LHOST.

So, use the command set, then LHOST is 10.35.1.198 I am also going to change LPORT.

So, use the command set LPORT is 443.

Now, use the command exploit to really open the handler and which can able to listen the connection coming from the target machine exploit.

So, now the reverse tcp handler is on in port 443.

Continued

Now somehow we need to execute the exe file in the target machine.

So, to do that we need to use any kind of social engineering method.

For the time being I am simply using a http server to execute the executable file in the victim machine.

So, I am opening a SimpleHTTPServer on port 8000.

Now see this is the executable which we already created.

Now, I am executing this file in the target machine and go back to the attacker machine where we open the listener and see we got the session and check the system information.

Wow now we are inside the Windows 7 machine.

Now, from the meterpreter session using the cell command we can directly go inside the target machine.

Continued

Now see, now we are inside the desktop of the target machine.

Now suppose I want to create some directory in the desktop.

So, using the command mkdir I am going to create a directory with the name kali.

Now, see already a file is created in the desktop of the target machine.

Now suppose I want to delete this particular directory and see it is already deleted.

Wow now to go back to the meta, to go back to the meterpreter session we can use the command exit.

Now if we use the exit command in meterpreter session, it will basically close the session with the target machine.

Tools mentioned

- **Metasploit**
- **msfconsole**
- **msfvenom**

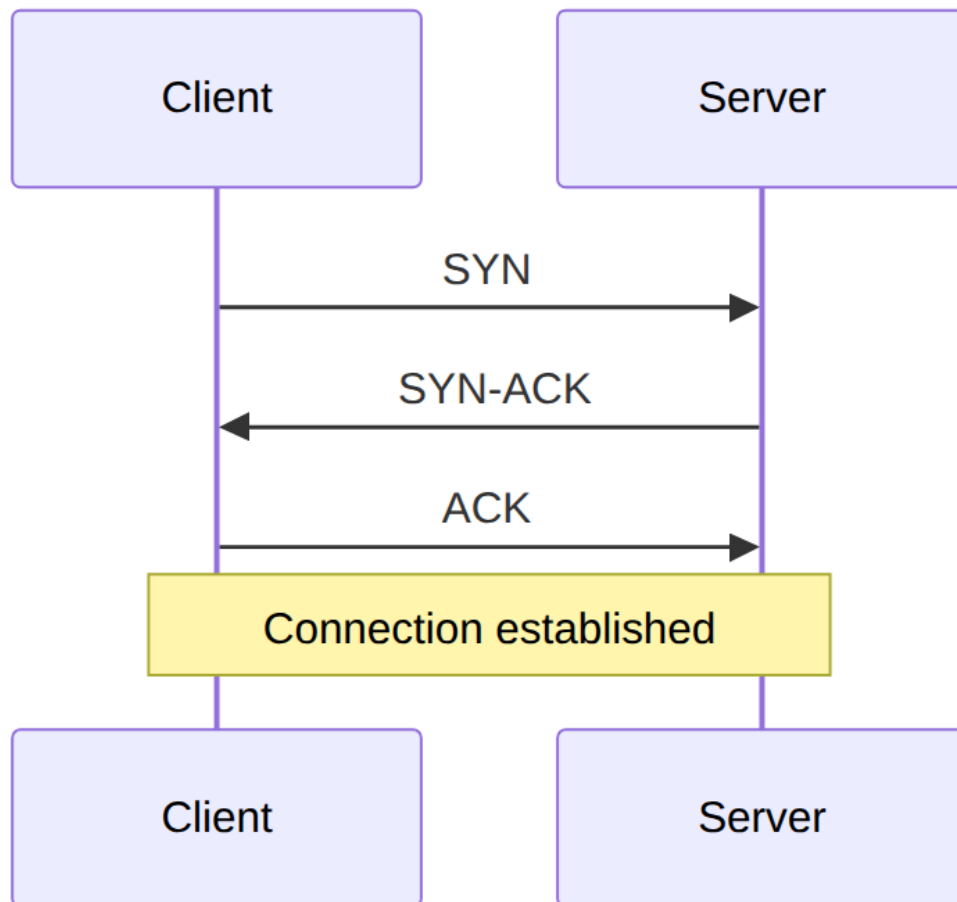


Figure 4: Architecture diagram

Commands / syntax from the lecture

- msfconsole I am opening the Metasploit framework

Key terms

Term	Meaning in this lecture
LHOST That	basically the IP address of the attacker machine. whenever we execute these executable in the target machine, it establish the connection with the host IP address 10.

Exam-oriented recap

- Now, in this session we will discuss about Social Engineering Attack.
- In this session we will use social engineering as an attack vector to compromise target system.
- It uses psychological manipulation to trick user into making security mistakes or giving away sensitive information.
- So, there are variety of techniques used for Social Engineering Attack.
- Best tool for Social Engineering Attack is SE toolkit.
- Now we are going to use this particular payload and create the executable and by using this payload, we try to establish a reverse connection from target machine to attacker machine.
- LHOST means basically the IP address of the attacker machine.
- That means whenever we execute these executable in the target machine, it establish the connection with the host IP address 10.35.1.198 and we can also set the LPORT.

L25: MITM (Man-in-the-Middle) Attack

Transcript: [25-mitm-man-in-the-middle-attack.md](#)

Video: <https://www.youtube.com/watch?v=qHoTTc-8DNw>

Week / theme: Week 5 — Nessus, system hacking, malware, ARP/MITM

Instructor: Prof. Indranil Sengupta, IIT Kharagpur

Learning objectives

- Today's session we will discuss about man-in-the-middle attack using the concept of sniffing via ARP poisoning.
- Now, we will show you a demo how to perform man-in-the-middle attack.
- So, now, for our scenario we will consider that this is our attacker machine with the IP address 10 dot 35 dot 1 dot 198.

What this lecture teaches

Core concepts from the lecture

Today's session we will discuss about man-in-the-middle attack using the concept of sniffing via ARP poisoning.

Address resolution protocol that means ARP is a stateless protocol used for resolving IP addresses to machine MAC addresses.

All network device that need to communicate on the network broadcast ARP queries in the system to find out other machines MAC address.

ARP poisoning is also sometimes known as ARP spoofing.

Now, the question is that how ARP works?

When one machine needs to communicate with another it looks up its ARP table.

If the MAC address is not found in the table, the ARP request is broadcasted over the network.

All the machines on the network will compare this IP addresses to MAC addresses.

Continued

If one of the machines in the network identifies this address, then it will respond to the ARP request with its IP and MAC address.

The requesting computer will store the address pair in its ARP table and communication will take place.

Now, the question is that what is ARP spoofing?

ARP packets can be forced to send data to the attacker's machine.

ARP spoofing constructs a large number of forced ARP request and reply packet to overload the switch.

The switch is set in forwarding mode and after the ARP table is flooded with spoofed ARP response the attackers can sniff all the network packets.

Attackers flood a target computer ARP catching with first entries which is also known as poisoning.

ARP poisoning uses man-in-the-middle access to poison the network.

Continued

So, the man-in-the-middle attack implies an active attack where the attacker creating a connection between the victim and send message between them in or may capture all the data packet from the victim.

In this case, the victims think that they are communicating with each other, but in reality the malicious attacker controls the communication.

A third person exists to control and monitor the traffic of communication between two parties that is client and server.

Some protocol such as SSL, serve to prevent this type of attack by encrypting the data.

Now, we will show you a demo how to perform man-in-the-middle attack.

So, now, for our scenario we will consider that this is our attacker machine with the IP address 10 dot 35 dot 1 dot 198.

And, this is our victim with the IP address 10 dot 35 dot 1 dot 199 and the default gateways 10 dot 35 dot 1 dot 2.

Now, from the attacker machine first we need to start port forward.

Continued

To check the port forward is enabled or not, we need to check the ip underscore forward file and the location of ip underscore forward file is under proc sys net and ipv4 directories.

So, to check that particular file ip underscore forward we use the command cat.

Cat is the command to see the content of a text file or to content of a file.

Cat then the location is proc sys net then ipv4, then the file name is ip underscore forward.

So, it written as 0; that means, it is disabled.

So, to enable it we need to write it as 1.

So, by using the echo command we can write in a file.

So, our next command is echo then 1 then the location is proc sys net ipv4 then the filename ip underscore forward.

Continued

Now, check the content of the file.

Now, see it is become 1; that means, it enable port forward.

Now, our next task is to perform the ARP poisoning.

So, to perform the ARP poisoning we use the command arpspoof.

Arpspoof then dash t specify the IP address of the target machine.

So, now, our target machine IP addresses is 10 dot 35 dot 1 dot 199.

Then we need to provide the IP address of the default gateway that is 10 dot 35 dot 1 dot 2.

Now, for the reverse connection we also need to perform the same thing, but this time we interchange the target and the destination.

Continued

Open a new terminal and again use the command arpspoof.

Now, this time target will be the default gateway that is 10 dot 35 dot 1 dot 2, then the IP address of the victim machine 10 dot 35 dot 1 dot 199.

This way we forward the both way traffic which is coming from the default gateway to target machine and which is going to the default gateway from target machine.

Now, we are able to place the attacker machine between the gateway and the target machine successfully.

Now, our aim is to capture the data packet which is sometimes known as sniffing technique.

Sniffing is the process of monitoring and capturing all the packet passing through a given network using sniffing tool.

It is a form of a tapping internet wire or maybe phone wire and get to know about the conversation or all the data.

There is so much possibility that if a set of enterprise switch port is open, then one of their employee can sniff the whole traffic of the network.

Continued

Anyone in the same physical location can plug into the network using Ethernet cable or connect wirelessly to that network and sniff the total traffic.

In other words, sniffing always allow you to see all sort of traffic both protected and unprotected.

In the right condition and with the right protocol in place and attacking party may be able to gather information what can be used for further attack or to cause other issues for the network or system owner.

One can sniff the sensitive information from the network via e-mail traffic, FTP password, web traffic, telnet password, router configuration, chat session, DNS traffic etc.

A sniffer normally turns the NIC, that means, Network Interface Card of the system to the promiscuous mode so that it listen to all the data transmitted on it segment.

Promiscuous mode refers to the unique way of Ethernet hardware in particular network interface card that allows an NIC all to receive all traffic on the network even if it is not address to this NIC.

By default NIC ignore all the traffic that is not addressed to it which is done by comparing the destination addresses of the Ethernet packet with the hardware address that is the MAC address of the device while this make perfect sense for networking.

Non-promiscuous mode makes it difficult to use network monitoring and analysis software for diagnosing connectivity issue or traffic accounting.

Continued

A sniffer can continuously monitor all the traffic to a computer through the NIC by decoding the information encapsulated in the data packet.

There are two types of sniffing are there; one is active and another one is passive.

In passive sniffing the traffic is locked, but it is not altered in any way.

Passive sniffing allows listening only.

It works with hub device.

On a hub device the traffic is sent to all the ports in a network that uses hub to connect systems.

All host on the network can see the traffic.

Therefore, it can easily captured traffic going through.

Continued

The good news is that now hubs are almost absolute nowadays.

Most modern network use switches.

So, passive sniffing is no more effective.

So, now, it is all about active sniffing.

In active sniffing the network traffic is not only locked and monitor, but it may also be altered in some way as determined by the attack.

Active sniffing is used to sniff a switch based network.

It involves injecting address resolution packet that is ARP packet into a target network to flood on the switch Content Addressable Memory table that is CAM table.

CAM keeps track of which host is connected to which port.

Continued

Now, by active sniffing technique, now for active sniffing technique MAC flooding, DHCP attacks, DNS poisoning, spoofing attack, ARP poisoning are there.

Now, we are demonstrated ARP poisoning.

Now, we are in the middle of the ARP poisoning.

Now, our aim is to open a sniffing tool.

The best sniffing tool I ever used that is wireshark; now to open the tool wireshark to capture all the data packet.

Now, select the interface eth0.

Now, my kali machine; that means, the attacker machine successfully placed between the default gateway and the attacker machine with the IP address 10 dot 35 dot 1 dot 199.

Now, I send some traffic from the victim machine and try to capture all that data packet from the attacker machine.

Continued

Now, see this is my victim machine.

And, from the victim machine I try to login into a web application a view dot in.

Now, in the login credential I put some login credential like username admin and I am giving some password and try to sign in.

Now, I am trying to capture all these data packets which is sent from the victim machine, from my attacker machine and go to the tool wireshark and filter those that data packet which have sent through http protocol.

Now, see, these are the data packet which have sent through http protocol.

These way we can also filter the data packet.

Now, see here is the data packet which sent to a view dot in login page.

Now, try to open the details of this data packet, right click on this data stream and follow TCP stream for the detail data.

Continued

Now, see, wow great, here is the username and password as I give in nptel1234.

This way by ARP poisoning and via sniffing technique we can perform man-in-the-middle attack and can capture all the data packet which is coming to the victim machine and which is going from the victim machine.

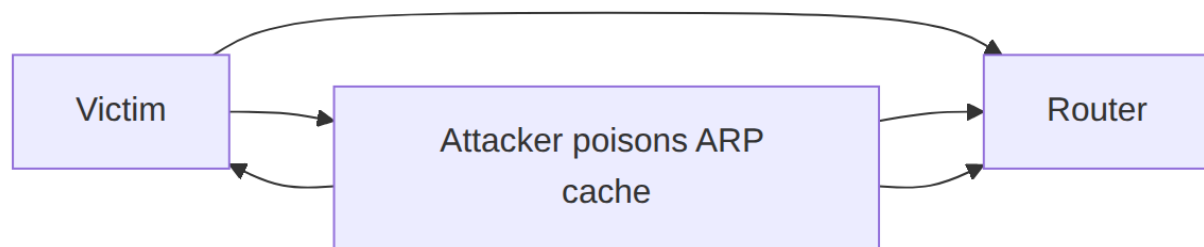


Figure 5: Architecture diagram

Tools mentioned

- Arpspoof
- arpspoof
- wireshark

Commands / syntax from the lecture

- Arpspoof then dash t specify the IP address of the target machine

Key terms

Term	Meaning in this lecture
Address resolution protocol that	ARP is a stateless protocol used for resolving IP addresses to machine MAC addresses.
Promiscuous mode	the unique way of Ethernet hardware in particular network interface card that allows an NIC all to receive all traffic on the network even if it is not address to this NIC.

Exam-oriented recap

- Today's session we will discuss about man-in-the-middle attack using the concept of sniffing via ARP poisoning.
- ARP packets can be forced to send data to the attacker's machine.
- The switch is set in forwarding mode and after the ARP table is flooded with spoofed ARP response the attackers can sniff all the network packets.
- Attackers flood a target computer ARP catching with first entries which is also known as poisoning.
- So, the man-in-the-middle attack implies an active attack where the attacker creating a connection between the victim and send message between them in or may capture all the data packet from the victim.
- In this case, the victims think that they are communicating with each other, but in reality the malicious attacker controls the communication.
- Some protocol such as SSL, serve to prevent this type of attack by encrypting the data.
- Now, we will show you a demo how to perform man-in-the-middle attack.

L26: Basic Concepts of Cryptography

Transcript: [26-basic-concepts-of-cryptography.md](#)

Video: <https://www.youtube.com/watch?v=O44EQCGZFUA>

Week / theme: Week 6 — Cryptography foundations

Instructor: Prof. Indranil Sengupta, IIT Kharagpur

Learning objectives

- Let us start by a very brief discussion on the security attacks.
- So, let us try to understand these four things one by one.

- Now, there are many ways and techniques that are used to try and strengthen the infrastructure so, that the chance of such attacks are minimized.
- I would never say that it will be 0, the chance is minimized or reduced.
- Well, cryptography is one of the most important and useful tools that are used to try and prevent these kind of attacks in a system or in a network.

What this lecture teaches

Core concepts from the lecture

Now, when we talk about hacking, breaking into a system, attacking a network what we actually are talking about; we are talking about identifying some vulnerability or weakness in an existing system and try to break into the system or the network or the environment or the organizational infrastructure whatever through that weakest link, weakest point.

Now, there are many ways and techniques that are used to try and strengthen the infrastructure so, that the chance of such attacks are minimized.

I would never say that it will be 0, the chance is minimized or reduced.

Well, cryptography is one of the most important and useful tools that are used to try and prevent these kind of attacks in a system or in a network.

In this lecture here I shall be trying to tell you some Basic Concepts of Cryptography which will help you in understanding and appreciating how many of the network based attacks take place and how you can prevent them, just using some techniques.

So, in this lecture we shall broadly be talking about some of the generic security attacks, some of the security services that are typically provided and some of the cryptographic primitives which are used to provide such security services.

Let us start by a very brief discussion on the security attacks.

Now, when we say security attack, we are saying that we have some kind of an infrastructure; I do not know what, that is, it can be anything and there is someone from the outside world who is trying to compromise the security or trying to break into my infrastructure.

Continued

So, security attack can be, could say anything, it can be of various types.

You can say, it can be any action that compromises the security of information.

I am not saying a network or a computer, I am saying information.

Ultimately a computer stores an information through a network, some information flows.

So, by virtue of some malicious operation which an intruder carries out on such a system or an environment, somehow this information content or information flow might get affected.

So, these are something which we refer to as security attacks.

Broadly speaking four kind of attacks you can identify or you can talk about: interruption, interception, modification and fabrication.

So, let us try to understand these four things one by one.

Continued

Our generic model is like this we are assuming that we have something like networking infrastructure, where there is a source, there is a destination.

Source is trying to send some message to a destination.

This is the thing which is being done and on this some kinds of attacks are being carried out.

Let us see with respect to these four, alright.

First let us talk about interruption, interruption conceptually is ver...

First let us talk about interruption, interruption conceptually is very simple.

This source was sending some data to a destination.

Somehow the intruder makes sure that this message never reaches the destination.

Well, you may ask how this can be done; now, you think of a typical network, there will be several routers through which the message packets are normally flowing through.

You may assume that there are multiple routers on the way, the message that source was sending was flowing through a number of routers and finally, it was reaching a destination.

Now, imagine an intruder has hacked a router.

Well, what is a router; router is nothing very sacrosanct, a black box, it cannot be hacked nothing like that.

Router is also like a normal computer, it is also a computer, there is a processor, there is memory, there are some IO facilities, input output facilities and it also runs an operating system like Linux or something.

Continued

So, it is ultimately it is a computer.

Now a computer can be hacked as you know.

So, a router if you treat it as a computer there is no reason why it cannot be hacked.

There is also some usernames and passwords, would through which some people or administrator can login into a router, can change some configurations and do a number of things.

And, the network ports and connections those are the input/outputs for the router, ok.

Now, suppose one of the routers is getting hacked and all packets which are coming into the router, they are either routed to a different direction or all packets are getting discarded.

So, these packets will never reach the destination, this is something called a denial-of-service attack.

You see someone is trying to contact a server, the server is providing a service, but if you somehow can stop that communication from happening; that means, you are not getting a service, it is denial-of-service ok.

Continued

So, interruption is an attack which is attack on availability.

So, so that you cannot contact the other side; the server, this server may be providing you with some facility.

It can be a web server.

It can be a mail server.

You are not being able to access it.

So, it is an interruption on availability of some service ok.

The second one is interception.

Well, interception means that source is sending some data to a destination fine.

Continued

There is a intruder in the middle, is silently listening to what is going on.

So, whatever I am sending to you some messages, some intruder is also reading those messages right.

Now, how it is happening; is it that someone is measuring what signals are going through a cable or an optical fiber.

Well, I am not saying that it is not possible, but it is extremely difficult, most common way of interception is again by hacking a router.

You hack a router, whatever packet comes, a copy of that packet you forward to some other place that will be the machine of the intruder.

So, intruder can read all the packets, everything will be coming as a copy to the intruder or so.

So, interception is an attack on confidentiality; meaning I may be sending you some confidential information like my bank account number or something, but someone in the middle can read the information and can get hold of that confidential information well.

Now, things are getting more complicated.

Continued

The third one is modification; well you again think of that model that some router in between has been hacked, but now what the intruder has done?

Intruder is more intelligent.

Intruder is not simply reading out the packets, but whatever packet is coming, the intruder is making some modifications in the packet and then forwarding it.

So, the destination will be receiving the packet alright, but it is not the original packet with some changes or modifications.

These are very dangerous, there maybe some critical messages which may be flowing between points; means you think of a scenario during a war.

There are some advanced posts to who are exchanging messages which are very critical for taking some strategic decisions.

Now, if the enemy can hack into their machines or servers or routers and change the messages then it can be catastrophic right.

Modification is something called attack on integrity.

Continued

I am saying that I was sending you a message.

The integrity of the message is lost.

Someone has modified the message in transit that is called integrity of the message right and lastly comes fabrication; fabrication says the source did not send anything at all to the destination, but the intruder artificially fabricated a packet with the source address put as the source address of S and the packet was sent to the destination.

Destination will feel that the packet is actually coming from S, but which is not; the packet was coming from the intruder and this is something called attack on authenticity.

You see authentication again becomes a very important issue here, authentication means the destination must be sure of the actual sender of the message or the packet.

Who is actually sending, is it S or someone else I is sending it by fabricating a packet ok.

So, these are broadly the security attacks which are very important in a very general context.

Now, there is another way you can classify attacks: passive and active; passive means it does not change anything.

Continued

Nothing is modified in the network or in the information that is flowing.

Passive attacks are those attacks where the intruder is simply obtaining some information.

It is reading some information which is flowing in the network.

This is sometimes called eavesdropping.

Someone is silently listening.

This is the most difficult kind of attacks to detect, because you as a user, as a participant you will have no idea that something wrong is going on.

But someone silently is listening everything whatever is flowing through your network, right.

This is called passive attacks.

Continued

Now, broadly passive attacks again can be of two types: one is messages as I said, I am sending your message.

Someone is reading that message.

Well, I may say that well I do not care because my messages are anywhere not very confidential, let someone read it.

But, there are cases where messages may be confidential, may be important and someone reading the message may not be desirable, but something else can also happen, there can be some kind of traffic analysis going on.

Like the intruder is trying to attack a remote a network let us say, but intruder does not have much information about the network.

It does not know which is the most important point where I should attack.

So, initially the intruder will try to listen to the packets that are flowing through the network and try to analyze the traffic that which are the computers, which are most heavily used.

So, it can identify one or two such very important or heavily used nodes in the network; they may be your web server, the mail server or something like that.

Continued

Then the intruder can pointedly try to attack those servers so, that maximum harm can be done to that network.

This is how traffic analysis can also be carried out to know some vulnerable points in the network; all right.

Now, talking about this active attacks, active attacks as it said are those where some kind of changes or modifications are taking place.

They involve some kind of modification of the data that are flowing through the network or through fabrication you can also create a false stream of data which was not there.

Some new or false data is injected into the network.

Now, here again under active attacks you can classify as four types; one is some kind of authentication attack masquerade, means one entity pretends to be a different entity.

Like I am sending a message to you telling that well I am mister x, but I am not mister x that is masquerade; I am masquerading as mister x, ok.

Replay; replay means I silently listen to network traffic and see that when someone is logging into a machine, some particular packets are being sent to a server which happens, which allows access.

Key terms

Term	Meaning in this lecture
Well, interception	that source is sending some data to a destination fine.
Someone has modified the message in transit that	integrity of the message right and lastly comes fabrication; fabrication says the source did not send anything at all to the destination, but the intruder artificially fabricated a packet with the source address put as the source address of S and the packet was sent to the destination.
This	passive attacks.
Replay; replay	I silently listen to network traffic and see that when someone is logging into a machine, some particular packets are being sent to a server which happens, which allows access.
You see how	you know that in the IP packet there is also a checksum field.
These are all	of checking the authenticity of the person, that whether it is a correct person who is trying to carry out the transaction.
Integrity	the messages should not be modified; suppose I am sending you some very important information and you should be sure that it is the original information and is not modified by someone else, ok.
Non-repudiation	something like this, let us say I had sent to a message, but tomorrow I say that well, I did not send to the message, maybe someone hacked and someone sent the message on my behalf.
private key	whenever I am garbling my message, I am doing it using some secret information that I am calling it a key and I am sharing that secret information with you, the intended recipient, right.
This	private or symmetric key encryption, but public-key encryption is something different.

Term	Meaning in this lecture
Public-key	there will be two keys with me, with one key someone can encrypt a message and send it to me, with the other key I can decrypt.

Exam-oriented recap

- Now, there are many ways and techniques that are used to try and strengthen the infrastructure so, that the chance of such attacks are minimized.
- I would never say that it will be 0, the chance is minimized or reduced.
- Well, cryptography is one of the most important and useful tools that are used to try and prevent these kind of attacks in a system or in a network.
- Let us start by a very brief discussion on the security attacks.
- So, security attack can be, could say anything, it can be of various types.
- You can say, it can be any action that compromises the security of information.
- So, these are something which we refer to as security attacks.
- Broadly speaking four kind of attacks you can identify or you can talk about: interruption, interception, modification and fabrication.

L27: Private-Key Cryptography — Part I

Transcript: [27-private-key-cryptography-part-i.md](#)

Video: <https://www.youtube.com/watch?v=XATa6FppLhA>

Week / theme: Week 6 — Cryptography foundations

Instructor: Prof. Indranil Sengupta, IIT Kharagpur

Learning objectives

- So, in this lecture we start with some discussion on private key cryptography techniques, this we shall be discussing in two parts.
- Now, in this part of the lecture, we shall broadly be discussing some of the private and symmetric key cryptography algorithms, particularly some of the classical techniques.
- So, in this lecture we start with some discussion on private key cryptography techniques, this we shall be discussing in two parts.
- Now, in this part of the lecture, we shall broadly be discussing some of the private and symmetric key cryptography algorithms, particularly some of the classical techniques.
- Now, talking about private or symmetric key cryptography, the basic concept is like this.

What this lecture teaches

Core concepts from the lecture

In the last lecture we talked about some of the security principles and services and we mentioned that encryption/decryption play a very important role in securing some kind of communication or a network in general.

So, in this lecture we start with some discussion on private key cryptography techniques, this we shall be discussing in two parts.

This is the first part.

Now, in this part of the lecture, we shall broadly be discussing some of the private and symmetric key cryptography algorithms, particularly some of the classical techniques.

Just recall whatever we will be discussing today in this lecture, the primary objective will be to give you a conceptual idea regarding private key encryption; but the practical algorithms which are really used, that we shall be discussing in our next lecture.

Now, talking about private or symmetric key cryptography, the basic concept is like this.

Well I have a message P that I want to transmit.

This message P in cryptographic terminology is called a plaintext.

Continued

Now what I try to do, I try to encrypt my plaintext or message into something called ciphertext.

Ciphertext is something which is garbled and if an intruder manages to even get hold of it, will not be able to decode what is the actual message that is been flowing through, ok And in symmetric key cryptography, there is a concept of a secret value called a key and this key is shared between the sender and the receiver, the same key is shared.

So, the way encryption and decryption are carried, functionally they are expressed like this; this EA stands for the encryption algorithm, well EA is like a function.

It takes two parameters, the plaintext and the key and it generates this ciphertext C , ok.

Similarly the decryption algorithm which is run at the receiver end, it will take the ciphertext as input and also the same value of key K and it will get back the original message or plaintext P .

This is conceptually how symmetric key cryptography works.

It is called symmetric or private key, because the same key is shared by both the parties, sender and receiver that is why it is called symmetric, or it is private between the two parties that is why it is called private.

Now, pictorially the same process as I have just now said is depicted in this diagram.

Continued

Now, in this diagram if you see, here is your plaintext, this is the sender side and this is the receiver side.

The plaintext goes through the encryption algorithm which also takes as input the shared key K , generates the ciphertext C which flows or is transmitted over the network, it reaches the receiving end.

The receiving end runs a decryption algorithm with the same shared key value K , it gets back the plaintext.

This is how symmetric key algorithms work.

So, the point to note is that the receiving end unless that party does not have the same value of the key K , will not be able to decode it which means an intruder which will not be having the value of K , well, even if the intruder knows the encryption and decryption algorithms, he or she will not be able to decode the cipher text, because the value of K is not known, ok.

So, the points to note, there are a couple of important points here; first thing is that, for this kind of encryption or decryption techniques it is understood or it is accepted that your method should be such that the overall security of this scheme must not depend on the secrecy of the algorithm.

Let the algorithm be known to everybody.

The important point is that the security should only depend on the secrecy of the key; as long as the value of K , the key K is only maintained by the sender and receiver means our communication will be very secure, this is the understanding.

Continued

So, it should not depend on the secrecy of the algorithm.

So, the assumptions in this regard, that are made are, that the algorithms encryption, decryption what we talked about, they are known to the public; but the keys are kept secret.

But there are some agencies which are involved in very high security transactions, like for example, the defense forces, they also prefer to keep their algorithm secret; now it is like a double edged sword.

So, if you keep the algorithm secret, maybe the intruder will find it more difficult to try and break your code.

But, because you are not making it public.

The general experts who are outside that organization will not be getting a chance to analyze that algorithm and identify whether there are any vulnerabilities or weaknesses, ok.

It is possible that the algorithm apparently looks very nice, but there are some very important weaknesses in the algorithm, which someone once is known can very easily exploit, fine.

Now, another point here is regarding the number of keys that are being handled.

Continued

Now you think of a communication system schematic.

Here I have shown it as a graph where A B C D E these are five communicating parties and they can communicate among each other, any pair.

So, when A and B are communicating, let us say along this path, so there will be some key which will be shared by A and B.

Let us say K1; when A and E are communicating there will be some other key value K2, so like this K3, K4, K5, for every pair of sender and receiver there will be a different value of secret key.

So, in general for n different parties, the number of distinct keys will be n choose 2, $n C 2$ which is nothing but n into n minus 1 by 2.

So, as you can understand as the value of n grows, the number of secret keys that the network has to maintain will grow very large; well if n is let us say, 1000, now this value will be 1000 into 999 by 2, close to 500000, ok.

So, maintaining so many distinct keys in a private way is itself a challenge; this is one problem.

So it is rather difficult to maintain secrecy of this large number of keys.

Continued

This is one problem in this method.

Now let us look at some of the classical private key encryption algorithms.

They broadly fall under two categories; well here I am assuming in the classical category that the message that I am transmitting is a simple text message.

It is not a non-text binary file.

I am transmitting, a text message.

The first category is referred to as substitution cipher, where we substitute each letter or a group of letters in the original plaintext by a different letter or a different group of letters so that my cipher text remains a textual data, but the letters are all garbled up.

And in transposition cipher, the letters are not replaced by anything.

Just the order of the letters are mixed up; they are permuted, some kind of permutation.

Continued

Like for example, if my letters are a b c, I can make it b c a or b a c something, this is called permuting the order of the letters.

So, let us see some of the classical techniques.

Well, one of the oldest ciphers or encryption method was referred to as Caesar Cipher.

This is essentially a substitution cipher, where every letter or alphabet in the plaintext is replaced by some other alphabet.

And the way it works is very simple, it says you replace each letter in your message by the letter which appears three places in the sequence of alphabet; like for example, if your, if you have a letter A, A will be replaced by B C D, A will be replaced by D.

Similarly, B will be replaced by E.

C will be replaced by F and so on.

Now, here we assume that the alphabets are cyclically rolled or chained like after Z again comes A.

Continued

So, for example, if my letter in the original plaintext is Y then Z A B this will be replaced by B like this.

This is an example is shown here.

If my plaintext is HAPPY NEW YEAR then H gets replaced by K, I J K, A by D, P by S, Y by B and so on, ok.

Like this, this substitution is carried out, ok.

This method is very simple as you can understand, but as such in this method there is no concept of a key.

I replace every letter by the fourth next letter, third next letter.

Now, you can generalize this Caesar cipher concept to make it dependent on a key as well.

So, what we do, we do not replace a letter by the next third letter, but we replace it by the k th next letter.

Continued

So, now, this value of k , this becomes our key.

So, if we number the alphabets A 1, B 2, C 3 up to Z 26; then for each letter the encryption and decryption process will work like this; encryption will be $P + k$ minus 1 modulo 26; modulo means divided by 26 and take the remainder plus 1.

Let us take an example, suppose I want to encrypt B, which in terms of the code, it is 2 and my key value is let us say 5.

So, my encryption how would, what will happen?

P plus k minus 1, now here P is this B 2, 2 plus 5 minus 1, so this is how much 6.

So, if you take modulo 26, divided by 26 and take the remainder, so it remains 6; 6 plus 1 is 7, it becomes 7; 7 is A B C D E F G, so, B will be replaced by G.

Let us take another example, suppose again k equal to 5 and I am trying to encrypt the letter Y which is 25.

So, now, this will be 25 plus 5 minus 1 modulo 26 plus 1.

Continued

So, this is 30 minus 1, this is 29; 29 modulo 26 is 3, divided by 26 and take the remainder, 3 plus 1 is 4, so A B C D; this Y will be replaced by the letter D, ok.

So, decryption is very similar, where you do minus k and you do plus 25 here.

Now you can check, you can get back the original letter once you have the value of k.

Now this method apparently is very simple, it should work; but the problem is that, here Brute Force attack is very easy, because we are talking about alphabets; the value of the key, the different values the possibilities are limited only there are 26 possible values, 1 upto 26.

So, you can exhaustively try all values of k and see for which value you get back a meaningful text that will be your key.

So, it is very easy to break, right.

So, this is not a practical method.

So, to make the process more complex and to increase the number of possibilities in the key, you can go for something called Mono-alphabetic cipher.

Continued

Mono-alphabetic cipher says, you allow any arbitrary substitution of the letters, not necessarily by the kth next letter.

For example, I can say that I will replace A by P, B by Z, C by A, D by M and so on, any arbitrary.

So, if I have this A to Z the string of 26 letters so, I can define a sequence like this.

This will mean the first letter A will be replaced by Z, second letter B will be replaced by A, third letter C will be replaced by Q and so on; the last letter Z will be replaced by P.

So, I am actually writing down a permutation of the 26 alphabets and that permutation becomes my key, ok.

Now; obviously, this will be much more difficult to break, because there is no easy way.

And the other thing is that for 26 things, 26 letters in the alphabet, the numbers of possibilities are 26 factorial.

So many permutations are possible, which comes to about 4 into 10 to the power 26; well which seems to be a very large number.

Continued

But the truth is that, this code is also not that difficult to break; because you can make some guesses.

Like you know in normal English text you know some typical frequencies of occurrence, which letter occurs the most frequent and pairs of letters T followed by H is very frequent; and similarly trigrams, three letters coming together, so how frequent are there.

So, if you make such a frequency count of all the letters, digrams and trigrams that appear in your ciphertex, then you can guess which is your A, which is your B, which is your C and like that you can break it.

So, using the relative frequencies it is rather easy to break this code.

Then you have another class of ciphers, where you do not replace a letter by other letter, but change their order.

So, one such commonly talked about cipher is called Transposition cipher, ok.

The transposition cipher, the idea is like this, suppose I have some message to be encrypted.

First thing is that I write out the plaintext in a rectangle; rectangle means, number of letters in a row is fixed.



Figure 6: Architecture diagram

Key terms

Term	Meaning in this lecture
This message P in cryptographic terminology	a plaintext.
So, one such commonly talked about cipher	Transposition cipher, ok.

Exam-oriented recap

- In the last lecture we talked about some of the security principles and services and we mentioned that encryption/decryption play a very important role in securing some kind of communication or a network in general.
 - But there are some agencies which are involved in very high security transactions, like for example, the defense forces, they also prefer to keep their algorithm secret; now it is like a double edged sword.
 - It is possible that the algorithm apparently looks very nice, but there are some very important weaknesses in the algorithm, which someone once is known can very easily exploit, fine.
 - But in a block cipher, we consider n bits of the block at a time; it can be 64 bits, 128 bits or 256 bits whatever is the value of n .
 - So, I take a certain number of bits of the cipher text, I convert it or decode it into plaintext or for encryption the reverse process.
 - I take certain number of bits of my original message, I encrypt it, receiving and I will decrypt it, this is called block cipher.
 - So, if my block size is smaller; then I will have to do some kind of padding, padding with zeros or ones to bring the block size to the required value.
 - So, with this we come to the end of this lecture; where we discussed some of the classical private key encryption algorithms.
-

L28: Private-Key Cryptography — Part II

Transcript: [28-private-key-cryptography-part-ii.md](#)

Video: <https://www.youtube.com/watch?v=o0GEPmHm87k>

Week / theme: Week 6 — Cryptography foundations

Instructor: Prof. Indranil Sengupta, IIT Kharagpur

Learning objectives

- Continuing with our discussion on Private-Key Cryptography, in this lecture we shall be looking at some of the practical encryption/decryption algorithms which have been used or which are being used.
- If you look at the literature, in the literature there is lot of research going on in the development of new algorithms.
- So, let us briefly look at the data encryption standard first.

What this lecture teaches

Core concepts from the lecture

Continuing with our discussion on Private-Key Cryptography, in this lecture we shall be looking at some of the practical encryption/decryption algorithms which have been used or which are being used.

So, the topic of this lecture is private key cryptography the second part.

Now, as I said now here we shall be revisiting some of the practical algorithms, which are used in real scenarios.

The algorithms that we will be talking about our Data Encryption Standard or DES, triple DES which is an extension of that and the most recently one, recent one which is most widely used nowadays is the Advanced Encryption Standard or AES, ok.

Talking about the practical algorithms, there are numerous algorithms in fact.

If you look at the literature, in the literature there is lot of research going on in the development of new algorithms.

There are good features in these algorithms, there are weaknesses, there are drawbacks, but the cryptographers or the persons who are developing these algorithms they are continuously trying to come up with better and better algorithms.

So, data encryption standard was one of the algorithms, which was proposed earlier in the 80s, where the block size was 64 bits.

Continued

So, it encrypted 64 bits of data at a time and the key size was 2, was 56 bits.

This DES was used for quite a significant amount of time, but because the key size is not that large, 2 to the power 56 in the present day context is not a very large number.

Using the fastest computer with brute force technique, you can generate all these keys and you can mount a brute force attack.

So, there are other algorithms which have been proposed, this idea is one of the algorithms which have been explored here also the block size is 64 bit, but the key size has been enhanced to 128 bits.

But as I said the most widely used symmetric key or private key algorithm today is called advanced encryption standard or AES.

This is also referred to as Rijndael cryptosystem taking a cue from the names of the inventors.

Here the block size is 128, but for the key size we have a choice.

You can have 128, 192 or 256 bits depending on the level of security that you want in a particular application; larger the key size, higher will be the security.

Continued

So, let us briefly look at the data encryption standard first.

So, as it said at one point in time this was most widely used.

This is also sometimes referred to as Data Encryption Algorithm or DEA.

As I said it is a block cipher which handles block size of 64 bits and the key size is 56 bits.

So, if you have a longer plaintext, then it will be split into blocks of 64, but in general the last block can be less than 64.

So, there will be some additional bits added to it, called pad to make this also 64 and accordingly using this algorithm the ciphertext will be generated, right.

This is how it works.

Now, I am not going to the detail explanation of how these are designed.

Continued

So, I am showing you the overall schematic how this DES is internally and what are the kind of steps that are being carried out to encrypt a given plaintext.

So, as I said, this is a block cipher with 64 bit of plain text so that 64 bit number is coming here at the top.

And, on the other side I have the 56 bit key that is coming here.

Now, you see in DES there are, there is a concept of a round.

In 16 rounds you are carrying out similar kind of calculations, but 16 times, one after the other.

So, what is the kind of calculation?

First these 64 bits that is coming, you do an initial transposition, jumble up the order of the bits.

This is called initial permutation.

Continued

Then this initially permuted value will go through the 16 rounds.

Then you do a 32 bit swap, because you have 64 bit number.

You take two 32 bit chunks and interchange their order.

The last you bring it to first.

The first to bring it to last and then again whatever permutation you used here, you use a reverse input permutation here, the reverse permutation here and whatever comes out that will be your 64 bit ciphertext.

But another thing you see each of these rounds is dependent on another factor which is coming from the right side.

These are the so called round keys.

The value of the round keys are different, not the same.

Continued

Although the value of K is same, PC is a permuted.

Choice some kind of key permutation is going on and first permutation then LCS is left circular, circular shift, this key is undergoing a circular shift left and using some combination function you are generating the round keys.

So, round keys are changing with the round number.

So, you see it is a quite complicated process through which I am generating the ciphertext from the plaintext.

Now each of these rounds I am not going into the exact functionality, but broadly speaking what happens in these rounds, are like this.

You see, the 64 bit plaintext that is coming and is going through each of the rounds, if you divide it to be into 2 parts, you call it a left part and a right part.

So, at the i th iteration, the left part is copied with i th part.

So, in the after around let us call it L_{i-1} and R_{i-1} .

Continued

So, when you generate the output of this round, this will be your L_i and this will be your R_i .

So, whatever this was here, this will get copied to L_i , L_i equal to R_i , but in this R_i you have a function.

This left part bit by bit exclusive-OR, some non-linear function.

This is a complex function of not only R_{i-1} , but also the round key that is coming from the right side.

So, this R_i is computed in a complicated way and any crypto, cryptosystem which have this kind of a, you can say structure there are many cryptosystems based on this structure, this is called in general Feistel structure, ok.

Now, as I said, DES as such is good, but the only concern is the short key length of 56 bits.

For critical applications we need keys of larger sizes.

So, the first attempt which was done or you may say explored is to use multiple runs of the DES algorithm to provide greater security.

Continued

So, here you have an algorithm which is referred to as triple DES.

As the name implies triple means, you are using DES three times for every encryption.

There will be three different keys, 56 bit keys for DES and there will be three executions of the DES algorithm for encrypting every 64 bit plaintext.

For every 64 bit plaintext, to encrypt it into a 64 bit ciphertext you will be requiring three executions or three runs of the DES algorithm.

The drawback obviously, is your method will become three times slower.

But the advantage is that you are using three 56 bit keys, 56 multiplied by 3 that is essentially your strength of the key, you can say the way it works is that from the plaintext you apply the first key carry out the DES encryption process.

Well decryption I have not shown.

Decryption process is also quite similar, but the rounds are executed in the reverse order.

Continued

So, whatever comes, you run the decryption algorithm with key K2 and whatever comes you again run the encryption algorithm with key K3.

The point to note on, note is that any data if we apply the encryption algorithm followed by the decryption algorithm you will get back the same thing.

Similarly, if you apply the decryption first followed by encryption then also you will be getting back the same thing.

So, this principle has been used in structuring this order of execution and as I said, 56 multiplied by three is 168.

So, effective key size is 168.

Here pictorially it works like this.

For encryption the plaintext is coming first.

You do an encryption with the first key K1, then decryption with K2, then encryption with K3.

Continued

You get the final ciphertext.

For decryption you do it in the reverse order.

In the last step you did an encryption with K3, you will do a decryption with K3.

In the middle you did a decryption with K2, you do an encryption with K2.

Here you did an encryption with K1, you do a decryption with K 1.

So, in sequence in the reverse sequence, encryption, decryption will cancel out, cancel out, cancel out and finally, you will be getting back the plaintext.

This is how triple DES works.

Triple DES has been also quite widely used.

Continued

In fact, in many of the money ATM machines, triple DES was used till some time back. So, this was quite widely used.

Now, there was a need for a new standard which was understood and identified, because DES was used for a pretty long time.

There was no apparent weakness in the algorithm.

The only concern was the key size, was smaller and many theoretical attacks designed by mathematicians were published which reduces the complexity of breaking DES.

So, DES was no longer considered to be very secure.

Well of course, triple DES is an option, but three executions of algorithm for every single encryption, is too much of an overhead, ok.

So, that also is some kind of a drawback.

Continued

Now, the standard organization NIST in US who actually standardizes the cryptographic algorithms, they came up with a call for ciphers in 1997.

They ask the mathematicians and scientists to publish their algorithms.

There will be like a competition.

They will be selecting the best of them as the next generation standard for encryption.

So, in that way there were 15 candidates which are finally accepted in 1998, were shortlisted and finally, the Rijndael cryptosystem was selected as the advanced encryption standard, in short AES.

Sometimes we refer to this algorithm as just the AES algorithm, ok.

Today this is one of the most widely used symmetric key algorithms that has been employed or deployed in many applications.

So, some features of this AES cryptosystem.



Figure 7: Architecture diagram

Key terms

Term	Meaning in this lecture
This	initial permutation.

Exam-oriented recap

- Using the fastest computer with brute force technique, you can generate all these keys and you can mount a brute force attack.
 - You can have 128, 192 or 256 bits depending on the level of security that you want in a particular application; larger the key size, higher will be the security.
 - So, the first attempt which was done or you may say explored is to use multiple runs of the DES algorithm to provide greater security.
 - The only concern was the key size, was smaller and many theoretical attacks designed by mathematicians were published which reduces the complexity of breaking DES.
 - Now, as I said whenever you are trying to secure a network, you find that there are some vulnerabilities.
 - There are a number of ways you try to secure your infrastructure or your data or files, whatever, now this encryption is one of the very commonly used tool or technique to provide you with the required level of security.
 - So, these encryption or decryption techniques can be integrated with other applications in a suitable way so that they can provide you with some levels of security as desired by some applications.
-

L29: Public-Key Cryptography — Part I

Transcript: [29-public-key-cryptography-part-i.md](#)

Video: https://www.youtube.com/watch?v=_kdwbXWsFgo

Week / theme: Week 6 — Cryptography foundations

Instructor: Prof. Indranil Sengupta, IIT Kharagpur

Learning objectives

- In this lecture we start with some discussion on Public-Key Cryptography.
- In the earlier case we discussed, there were n into n minus 1 by 2 keys which was the close to n square by 2, quite large.
- So, again let us explain it pictorially, this is the schematic of a public key encryption system.
- So, I said the receiver B will be having a public key K_{UB} and we will be having a private K_{RB} , right.

What this lecture teaches

Core concepts from the lecture

In this lecture we start with some discussion on Public-Key Cryptography.

The title of this lecture is public key cryptography, first part of it.

Now earlier we have seen symmetric or private key cryptography, where the same key was shared by the two end systems, sender and receiver, but you think of the

internet scenario; in the internet scenario we are already habituated with sending and receiving messages between parties who are widely separated geographically.

So, the natural question arises if I request secrecy, if I require privacy of my data, suppose I am sending some packets, a message to my friend, who is sitting 1000 kilometres away from here, first thing is that I can use these symmetry key algorithms for encryption, but how do we share the key?

Shall we call each other and tell the key over telephone, but telephones can be trapped?

So, there should be some secure mechanism for sharing these keys also.

In general, in the internet scenario there should be some technique where people who are sitting at a large distance from each other, not being able to communicate safely or securely using conventional medium can also carry out and enforce some kind of security in terms of the data communication.

So, in this lecture we shall be talking about public key cryptography as I said and you will see that this public key cryptography can be used for encryption as well as authentication purpose and one of the most popularly used algorithm, the RSA that we shall be discussing.

Continued

Now, talking about public key cryptography, here the concept is slightly different from symmetric key cryptography.

Now in symmetric key cryptography what is happening?

There was a sender; there was a receiver; there was a communication channel.

So, you define a secret key which was shared by both the parties, this was what was happening in symmetric key systems.

But in public key system what we are saying, it is something different.

I have a sender; I have a receiver; there is a communication channel; now I am saying that I am not sharing any key across 2 parties.

Let us say, there can be a third party, also X.

There are three parties.

Continued

So, now, what I am saying is that, every party will be having 2 keys.

A pair of keys, one is called a public key; one is called private key.

Notationally I can denote the public key by KU, KUS and the private key by KRS.

So, here there would be KUR and KRR and here KUX KRX.

So, every party will be having 2 keys, the first thing you see that the number of keys are getting drastically reduced here.

If there are n number of parties, there will be only 2^n different keys.

In the earlier case we discussed, there were n^2 keys which was the close to n^2 , quite large.

Here the name is going to say, public and private.

Continued

Say everybody is having 2 keys.

I am also having 2 keys.

So, one of my keys is a public key; one is a private key.

The idea is that public key I am free to tell everybody.

So, I can announce that this is my public key to anybody I want to, but my private key I will keep secret with myself.

I will not tell anybody in this world.

I will keep it in my pocket.

I will keep or maintain the secrecy of my private key.

Continued

This is the idea of public key cryptography systems.

Now let us see how it works.

So, again let us explain it pictorially, this is the schematic of a public key encryption system.

Let us say there is a sender A which wants to securely send some data to a receiver B.

So, I said the receiver B will be having a public key K_B and we will be having a private K_B , right.

The idea is that when somebody, in this case A wants to send a message to B through encryption, what it does?

There will be an encryption algorithm which will be using B's public key.

B's public key is supposed to be known by everybody.

Continued

So, A also knows that.

A knows B's public key and using B's public key this plain text is getting encrypted into the cipher text.

What the receiver is doing?

The receiver is running a decryption algorithm, but now this decryption algorithm is using B's private key which is only present with B.

This algorithm is such, designed in such a way that if you encrypt using public key, then you can decrypt using private key or also the reverse.

If you encrypt using private key, you can decrypt using the public key.

Now in this case for encryption we are saying we will be encrypting using public key which is known to everybody, but it can be decrypted only by the private key so that I can receive message from many people, because my public is known to everybody, but no one else will be able to decode that messages other than myself, because only I am having the private key, right.

This is how this encryption occurs in public key system.

Continued

Now just by slightly changing the configuration or the order of these operations.

We can also allow some kind of authentication process to take place using the same kind of process.

First thing is that this is what we are saying encryption.

I just now told public key is known to everybody.

private key is only available with B.

So, many parties can send the message, but only B can decode.

Now, let us talk about another application of public key cryptography namely, authentication.

Here also let us say A is sending something to B; A sending something to B, but for authentication application we will be using the keys of the sender.

Continued

A is having a public key KUA, A is having a private key KRA.

Now you see the purpose of authentication is not to send a message securely, but to make the other person identify or believe that I am the correct person, whom I am claiming to be, right.

Well let us imagine a situation.

Suppose A wants to authenticate itself with B.

Let us say A chooses a random text P.

This P can be a Shakespeare's poetry, a Shakespeare's text let us say.

So, anything which is legible, which someone can read and understand you can select any such plaintext and you encrypt it using your own private key.

Well, I am trying to authenticate to you.

Continued

I encrypt it with my private key.

I send it over to you.

The cipher text is generated.

It is sent to the receiver.

What the receiver will do?

Receiver will try to decode it using the sender's public key which is of course, known.

So, as I said, this public key and private key encryption/decryption are interchangeable.

You can use one of them for encryption, the other for decryption.

Continued

So, what the receiver will see that if I use A's public key for decryption, I am getting back a message which I can read and understand which means I am using the correct public key; that means, it must have been encrypted by A, using A's private key.

So, I can uniquely identify A, right.

This is how authentication works in this case.

So, just by changing the; but to say here I am saying, I am not talking about the secrets of messages.

This A is encrypting it using its own private key, the entire world knows my, suppose I am A, the entire world knows my public key.

So, anyone can decrypt it, let them decrypt.

I do not care, I am only concerned with the receiver B, B should be able to decrypt it and identify that well I am actually A, but let the others also do the same thing I do not care, fine.

Now, this is the pictorial schematic, now we encrypt using the private key of the sender and it is send out.

Continued

Anybody, that anybody can verify the authentication of A by using the public key of A decrypting it.

Now this, application of these public key algorithms encryption/decryption algorithms, broadly you can think of three different applications.

First is of course, encryption/decryption as I had said, the sender encrypts the message with the receivers public key, the receiver will decrypt it in its own private key.

This is quite possible, but the only problem is, I, we shall be talking about this later, is that these are relatively slow with respect to symmetric key algorithms.

These methods will take more time for encryption and decryption.

Digital signature is something we shall be discussing later.

So, now, you are aware of this terminology that we conventionally put our ink signature on a paper to authenticate that well, I am the person who read and I am signing it.

So, there is an equivalent electronic signature also which is called digital signature that is also becoming quite popular nowadays.

Continued

That can also be implemented using these kind of public key crypto algorithms and key exchange; 2 persons can cooperate to exchange a key.

This we shall see later again.

Now for a public key crypto system as I had said every party must be holding a pair of keys, private key and public key.

So, there are some essential requirements for this algorithm to use, because in an environment new users can join.

So, when a new user joined, the new user should be given a pair of public and private keys new pair.

So, it should be computationally not very difficult to generate a key pair, public key and private key.

Somebody should be able to generate that pair of keys relatively easily and these easy are relative terms.

So, you should be able to do the encryption process for a message using let us say the public key of B and for the receiver side the reverse process decrypt using the private key of B.

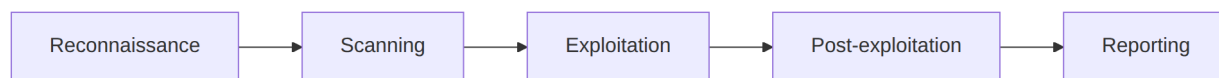


Figure 8: Architecture diagram

Key terms

Term	Meaning in this lecture
A pair of keys, one	a public key; one is called private key.

Term	Meaning in this lecture
So, there is an equivalent electronic signature also which	digital signature that is also becoming quite popular nowadays.
This Select e such that the GCD of e and phi n is 1 which	d multiplied by e will be equal to 1 mod phi n. relatively prime to phi n, that is.

Exam-oriented recap

- Now for a public key crypto system as I had said every party must be holding a pair of keys, private key and public key.
- Now, the other things are related to the security of the schemes.
- Now you must say that well I can choose a prime number 5 and 13; is it good enough?
- So, I said $d \cdot e$ equal to 1 mod phi n, but from number theory you can, it can also be proved that this will be 1 also mod n, So, I am not going into the proof, but just remember this.
- The only constraint is that whatever integer of values represents, this must be less than that value of n that you have selected during the key generation process.
- So, the security of RSA is based on this assumption that factoring the product of 2 prime numbers is currently not possible, large prime numbers of course.
- So, the security of RSA is based on that assumption, right.
- Whenever you want to send a, let us say large message to some parties sitting somewhere far apart in a secure way, well you can do it in a 2 step process.

L30: Public-Key Cryptography — Part II

Transcript: [30-public-key-cryptography-part-ii.md](#)

Video: <https://www.youtube.com/watch?v=scKGmB-I-pA>

Week / theme: Week 6 — Cryptography foundations

Instructor: Prof. Indranil Sengupta, IIT Kharagpur

Learning objectives

- In the last lecture if you recall, we were discussing about generally the public key cryptography, the concept and in particular the RSA algorithm.
- So, we continue with our discussion in this lecture so, where we shall be looking at some other cryptographic public key cryptography schemes and some of the

issues.

- So, we continue with our discussion in this lecture so, where we shall be looking at some other cryptographic public key cryptography schemes and some of the issues.
- So, here the idea is that two parties, two parties can exchange a set of messages and finally, they can agree on a secret key.
- And this channel over which they are exchanging, this is assumed to be insecure.

What this lecture teaches

Core concepts from the lecture

In the last lecture if you recall, we were discussing about generally the public key cryptography, the concept and in particular the RSA algorithm.

So, we continue with our discussion in this lecture so, where we shall be looking at some other cryptographic public key cryptography schemes and some of the issues.

So, what we will be looking at first, is something called Diffie Hellman key exchange which is also a public key kind of an algorithm and lastly, we shall be briefly talking about something on message authentication which of course, we shall again be coming back to later.

So, Diffie Hellman key exchange is a very conceptually simple method for exchanging key between two parties; it does not use RSA, but a different kind of an algorithm which was also proposed long back in the 1970s, 76.

So, here the idea is that two parties, two parties can exchange a set of messages and finally, they can agree on a secret key.

And this channel over which they are exchanging, this is assumed to be insecure.

Insecure means the hackers may be able to hear whatever is going on.

So, you should not be sending something using which the hacker will be able to know that what secret key we are finally, agreeing on.

Continued

So, Diffie Hellman key exchange is one such algorithm which allows us to do that.

But this is not an algorithm for encryption/decryption, just make it very clear.

It is only used for agreeing on a common shared key.

Just like we mentioned in the last lecture that you can use the RSA algorithm to generate an unknown number and send it to the other side and that random number can become the key, ok.

Not like that, it is something similar we do here.

Now for RSA, you recall, we mentioned that the difficulty of breaking RSA is based on the computational difficulty of factoring the product, have two prime numbers.

Diffie Hellman key exchange is also based on a similar mathematically complex problem.

It is called discrete logarithm problem.

Continued

This we shall talk about a little later.

Let us look into the algorithm first.

Diffie Hellman algorithm, the way it works, let us say there are two parties A and B which want to agree on some common shared key and there is a communication channel between them.

I am assuming that this communication channel is not secure.

There can be some eavesdropper.

There can be some intruder which may be listening to whatever is going on in the channel.

This is our model and assumption.

First thing is that A and B agree on some two large numbers n and g .

Continued

g is of course, less than n .

So, this n and g values are available to both A and B and this n and g has something which A has communicated to B over this channel.

So, the intruder may also have, they have these values of n and g .

So, n and g on nothing which are very secret, I am assuming that the world knows because I have sent it over in a secure channel.

Now the steps in the algorithm, it will, A chooses a random number x .

These numbers are all large numbers.

So, I am not mentioning it separately, but these are all large numbers.

A chooses a number x .

Continued

Let us say small x , small x and it calculates capital X equal to g to the power x mod n and this capital X is sent to B.

B does a similar thing.

B chooses some other random number y and it calculates capital Y equal to g to the power y mod n and sends it back to A.

Now you see, you think of the intruder, say intruder knows X which is $g^x \bmod n$.

It knows Y which is $g^y \bmod n$ because these are the numbers which have been communicated over the channel, which I is hearing.

Now the discrete logarithm problem says that if I know g , if I know n , if I know X then what is the value of x ?

Similarly, for the other case if I know g , n and capital Y , what will be the value of y ?

This is the discrete logarithm problem which is known to be computationally very difficult.

Continued

So, this Diffie Hellman key exchange algorithm is based on this assumption that even if the intruder knows X and Y , intruder will not be able to find what are the values of x and y , small x and small y , ok.

Now, after this stage what happens when A receives this Y , capital Y from B.

So, it does again a Y to the power x , small x and B receives x and does a X to the power small y .

So, at the end what will happen?

Both A and B are having the same value g^{xy} , but I, this poor fellow cannot do this.

I will not be having g^{xy} , because I is only seeing this capital X and capital Y which are flown through the channel, but small x , small y values, these are only lying with A and B and finally, thought A and B will be having the value, same value of key which is given by $g^{xy} \bmod n$.

This is how key exchange happens.

Pictorially I am showing it like this, same thing which I have just now mentioned, ok.

Continued

So, A chooses small x .

A sends this capital X to B.

B sends capital Y to y.

Finally, A computes Y to the power $x \bmod n$ and B computes X to the power $y \bmod n$.

Finally, they both get the same value of key.

This is how Diffie Hellman key exchanged works.

So, this method is interesting, good in the sense that there is no prior communication required between the A and B.

They do not need any public key like in RSA to be known by the other party and so, on.

Continued

So, from scratch you are starting on communication and you are agreeing only the value of g and n has to be sent at the beginning and after that they can agree on the common key, shared key.

And as I had said the security depends on the discrete logarithm problem that given known value of X , g and n .

What is the difficulty of computing small x ?

That is and just one point is that I just mentioned g and n are chosen initially, but there are some issues or constraints you need to follow when you are choosing the values of g and n .

Like the value of n should be such that n and also $n - 1$ should be prime, because some attacks have been discussed by mathematicians where they said that if such constraints are not satisfied, then it may be feasible to attack Diffie Hellman system and since of course, the value of n should be large.

But one problem here is that there is a man-in-the-middle attack or intruder in the middle attack, where there is an active intruder.

Here Diffie Hellman key exchange might mislead itself.

Like I am just telling you the basic idea.

Continued

Just you think of a scenario like this, this A and B are sharing a communication channel and there is a intruder who has been looking at the message exchanges and have understood what kind of message exchange are going on.

So, normally what would happen is that, this A and B would be using Diffie Hellman key exchange between themselves and would agree with the common shared key k between them.

Then they can exchange messages, use an encrypted way.

Using this message key B can send something to A , A can send something to B and so, on.

Now, suppose what happens is something like this.

This A is not sending anything right now, but B is fabricating a message.

This intruder, this intruder is fabricating a message.

What the intruder will do?

Continued

Intruder will act as if intruder is A.

So, intruder will be sending a packet to B with the initial values of g and n , but these are all fabrication attack, attacks and then again it will choose a number x and we will send the value of g to the power $x \bmod n$ to B.

So, B will do the same thing.

B will in good faith assume that this is A.

It will send it back.

It will not send it back here.

It will send it back to A, but this intruder will also capture that same packet.

But the first message was initiated not by A, but by the intruder.

Continued

So, intruder has the value of x .

B does not know that B is sending a similar packet to A which the intruders is also capturing.

So, what will happen at the end is that.

The key k that has been shared will be shared between B and intruder, not between B and A, because the small x was generated by intruder.

A does not know about small x .

So, now, B whatever sends in an encrypted way using key k , intruder can intercept.

It can decode it back.

Some message privacy might get compromised.

Continued

So, this is called, something referred to as man-in-the-middle attack or the intruder in the middle attack.

So, this Diffie Hellman method is susceptible to man-in-the-middle attack.

So, this you should remember where the intruder is an active intruder, is fabricating packets and is trying to mislead B into believing that intruder is actually a fine.

Now here I am showing a quick comparison between symmetric key and public key cryptographic algorithms.

I have just, I have said very loosely that these symmetric algorithms are much faster as compared to public key.

Just a simple comparison the RSA algorithm when it carries out encryption or decryption, this speed is thousands of bits per second or kilobits per second.

But DES, well AES is even faster than DES.
DES is millions of bits per second.

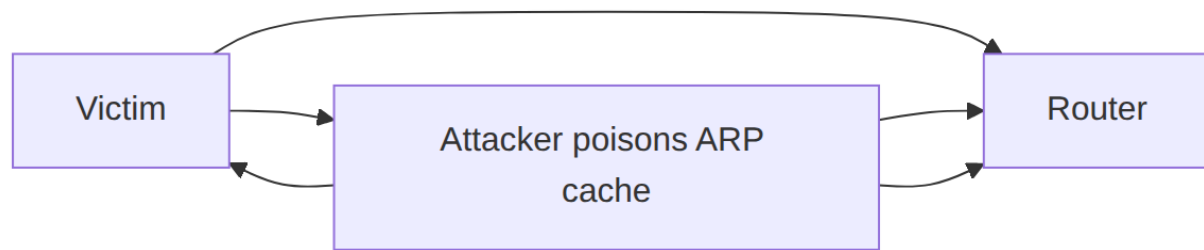


Figure 9: Architecture diagram

Key terms

Term	Meaning in this lecture
Insecure	the hackers may be able to hear whatever is going on.
Now message authentication	a sender has to authenticate itself with the receiver.

Exam-oriented recap

- And as I had said the security depends on the discrete logarithm problem that given known value of X , g and n .
- But one problem here is that there is a man-in-the-middle attack or intruder in the middle attack, where there is an active intruder.
- So, intruder will be sending a packet to B with the initial values of g and n , but these are all fabrication attack, attacks and then again it will choose a number x and we will send the value of g to the power $x \bmod n$ to B .
- So, this is called, something referred to as man-in-the-middle attack or the intruder in the middle attack.
- So, this Diffie Hellman method is susceptible to man-in-the-middle attack.
- So, this you should remember where the intruder is an active intruder, is fabricating packets and is trying to mislead B into believing that intruder is actually a fine.
- We shall be discussing this thing later, but the point to note is that authentication is a very important security primitive that is used to build security applications.
- So, with respect to the security of an organizational network, this authentication is something which is very important.